

COMPLETE CODEBASE SECURITY AUDIT & VULNERABILITY REPORT

Media Infotech Platform • Exhaustive Vulnerability Review (20 Identified Flaws)

Ref & Severity	Vulnerability Details & Endpoint	Affected Location	Recommended Remediation
SEC-01 HIGH	Insecure Direct Object Reference (IDOR) & Mass-Assignment on Employee Dossiers PUT /api/users/:id/profile Impact: Unrestricted profile & financial updates (CTC, bank details, PAN, reporting manager) across all employee accounts.	user.controller.ts (L171-L225)	Enforce req.user.id check or require ADMIN/HR role; strip restricted fields (ctcAnnual, managerId, salaryStructure) from non-admin payloads.
SEC-02 HIGH	Salary Structure & Compensation Breakdown IDOR Leakage GET /api/payslips/salary-structure Impact: Regular employees can query full compensation (Basic Pay, HRA, PF, Tax, Gross CTC) of any colleague or executive.	payslip.controller.ts (L5-L25)	Restrict GET /api/payslips/salary-structure to own userId unless user has ADMIN, HR, or ACCOUNTS role.
SEC-03 HIGH	Chat History & Private Message IDOR Leakage GET /api/chat/channels/:id/messages Impact: Any employee can read private 1-on-1 direct messages or executive chats without membership.	chat.controller.ts (L429-L485)	Verify chatParticipant membership or channel public status before returning messages.
SEC-04 HIGH	WebSocket Private & Direct Channel Authorization Bypass WS send_message / join_channel Impact: Users can inject messages into private executive channels or direct conversations without membership.	socket/index.ts (L173-L215)	Check prisma.chatParticipant membership on join_channel and send_message events before database insert.
SEC-05 HIGH	Unauthenticated Direct Static File Access on Sensitive Documents & Payslips GET /uploads/* (Static Public) Impact: Public static serving allows direct unauthenticated download of payslips, identity proofs, and expense receipts.	src/index.ts (L89-L92)	Protect /uploads route with authenticateToken or create authenticated streaming endpoints for sensitive document types.
SEC-06 HIGH	Unrestricted Tender Project Creation & Mutation by Unprivileged Users POST/PUT /api/projects Impact: Any regular employee can create or edit government tender projects, contract values, EMD amounts, and milestone schedules.	project.controller.ts (L392-L660)	Require requirePermission('projects', 'create' / 'update') or restrict to ADMIN, MANAGER, HR roles.
SEC-07 HIGH	Employee Hours & Extra Hours Analytics IDOR Leakage GET /api/attendance/employee-hours Impact: Regular employees can inspect colleagues' daily check-ins, late arrivals, extra hours, and leave schedules by passing target userId.	attendance.controller.ts (L600-L650)	Enforce if (targetUserId !== req.user.id && ![ADMIN, HR, MANAGER].includes(req.user.role)) return 403.
SEC-08 HIGH	Unauthorized Document Vault Deletion without Ownership Verification DELETE /api/users/documents/:docId Impact: Any authenticated user can delete employment contracts, NDAs, and ID proofs of other employees.	user.controller.ts (L447-L455)	Verify document ownership (doc.userId === req.user.id) or require ADMIN/HR permissions before deletion.
SEC-09 MEDIUM	Missing Session Revocation upon Password Reset / Password Change POST /api/auth/reset-password Impact: Resetting or changing passwords fails to delete active refresh tokens from prisma.session, keeping compromised sessions alive.	auth.controller.ts (L168-L280)	Delete all active sessions (prisma.session.deleteMany({ where: { userId } })) upon successful password change/reset.
SEC-10 MEDIUM	Financial Segregation of Duties Bypass: Self-Approval of Expense Claims PUT /api/expenses/:id/status Impact: Accounts, Managers, and HR users can approve and mark their own reimbursement claims as PAID without dual-control.	expense.controller.ts (L87-L115)	Disallow self-approval by checking if (claim.userId === req.user.id) return res.status(403).
SEC-11 MEDIUM	HR Dual-Control Bypass: Self-Approval of Submitted Leave Requests PUT /api/leave/:id/status Impact: Managers and HR users can approve their own submitted leave requests without independent managerial review.	leave.controller.ts (L396-L430)	Prevent self-approval: if (leave.userId === req.user.id) return res.status(403).
SEC-12 MEDIUM	Stored XSS Risk via Unrestricted SVG Image Uploads File Upload Multer Engine Impact: Allowing image/* without filtering SVG permits uploading .svg files with embedded <script> tags.	upload.middleware.ts (L105)	Explicitly exclude .svg from accepted image MIME types or sanitize SVGs with DOMPurify.
SEC-13 MEDIUM	Group Announcement & Discussion Comment Deletion Without Ownership Check DELETE /api/groups/:id/announcements/* Impact: Any group member can delete announcements and discussion replies created by others.	group.controller.ts (L510-L560)	Verify authorId === req.user.id or verify user has ADMIN/MANAGER role prior to deletion.
SEC-14 MEDIUM	Missing Route-Level RBAC Guards on Employee Offboarding & Purge POST /:id/offboard, DELETE /:id/purge Impact: Critical employee offboarding and permanent data purge routes lack explicit route middleware guards.	user.routes.ts (L43-L46)	Attach requirePermission('users', 'update') and requirePermission('users', 'delete') middleware directly to routes.
SEC-15 MEDIUM	Permissive CORS Dynamic Reflection with Allowed Credentials Global HTTP / Socket CORS Impact: Reflects any origin with credentials: true, enabling potential Cross-Origin resource abuse.	src/index.ts (L50-L60) & socket	Replace dynamic reflection callback with strict whitelist array of allowed production domains.
SEC-16 MEDIUM	Hardcoded JWT Secret Fallbacks in Production Code JWT Engine Impact: If .env is missing, predictable fallback keys allow token forgery.	utils/jwt.ts (L3-L5)	Throw fatal startup error if JWT_SECRET or JWT_REFRESH_SECRET environment variables are missing.
SEC-17 MEDIUM	Client Sub-Resource Deletion Without Parent Verification or Audit Logging DELETE /api/clients/:id/services/* Impact: Services and transactions can be deleted by ID without verifying parent client ownership or producing audit trails.	client.controller.ts (L260-L280)	Ensure service/transaction belongs to clientId and log deletion in audit logs.
SEC-18 LOW	Unverified Equipment Custody in Ticket Inventory Consumption POST /api/tickets/:id/consume-inventory Impact: Field technicians can mark central warehouse hardware or other technicians' items as installed without custody check.	ticket.controller.ts (L882-L1010)	Verify item.userId === req.user.id or item.groupId === ticket.groupId.
SEC-19 LOW	Lack of WebSocket Event Throttling & Geolocation Range Validation WS Events / GPS Check-In Impact: Risk of socket message flooding and out-of-range latitude/longitude coordinates causing database exceptions.	socket/index.ts & attendance.controller.ts	Add socket event sliding window limiter and bound lat (-90 to 90), lng (-180 to 180).

SEC-20
LOW

Plaintext Access Token Storage in Browser LocalStorage

Frontend Client API Client

Impact: While refresh token is secured in httpOnly cookies, access token in localStorage is vulnerable if XSS occurs.

Mediainfotech-Web
lib/api.ts (L26)

Keep access tokens in memory or use Next.js server-side route proxies with secure cookies.